PART A INTRODUCTION

1. SECURITY ARCHITECTURES FOR NETWORK AND INFORMATION SYSTEMS

The current standard structure of network and information systems has reached a particularly high degree of complexity. Its main features are the following:

- *Central building infrastructure* with servers that have public IP address (web, mail, DNS etc.) and several internal networks that host employee workstations. Occasionally, employees bring their own portable devices (laptops, tablets, smartphones), which are connected to the organizational network, as well as their own portable storage media (USB, external hard drives, etc.).

- *Remote offices* of the same entity in other geographical areas with their own respective internal network infrastructure.

- *Organizational software, usually web applications, hosted in data centers* of one or more cloud service providers.

- *Organization's employees who work from home (teleworking)*, are remotely connected to the corporate internal network and handle its critical data from their home network and by using PCs that have not been audited by the entity's IT department.

- *Third party providers and suppliers* who have undertaken the development of applications as well as the technical support of the organization's systems, are connected remotely to its internal network through their infrastructure or have assigned the work to their own subcontractor.

A wide and difficult to control dispersion in the processing, storage and circulation of an entity's data is observed, while at the same time the classical network perimeter is no longer clearly demarcated. All the above take place in an interconnected world that becomes increasingly vulnerable to malicious activity as interconnectivity, device plethora, distributed applications and services, as well as complexity in cloud and multi-cloud environments increase.

It is obvious that this degree of complexity greatly increases the security requirements for the protection of an organization's critical data from leakage, deliberate alteration or even interruption of availability. To accomplish effective defense against ever-evolving threats, various architectural models have been proposed, two of which are briefly described below.

THE "DEFENSE-IN-DEPTH" ARCHITECTURE

In this model, security measures and mechanisms are applied in the form of successive layers throughout the network and data of an organization to protect them from threats. Each individual layer does not counter every threat, while when jointly applied they can mitigate an extended variety of offensive techniques. If a threat succeeds in bypassing one layer, it has to deal with the defense mechanisms of the next layer. An effective defense-in-depth strategy includes mechanisms at a technical level, as well as organizational / administrative measures, such as:

- Policies and procedures (risk analysis, user training, supply chain management, etc.),
- Access restrictions (least privilege, need-to-know, etc.),
- Network security (network segmentation, firewalls, intrusion detection systems, VPNs, etc.),
- Device protection (antivirus, application whitelisting, etc.),
- Application and data protection (patching, data backup, encryption, etc.)

Figure 1 below graphically illustrates an example of a sequential layering of the "defense-in-depth" architecture.

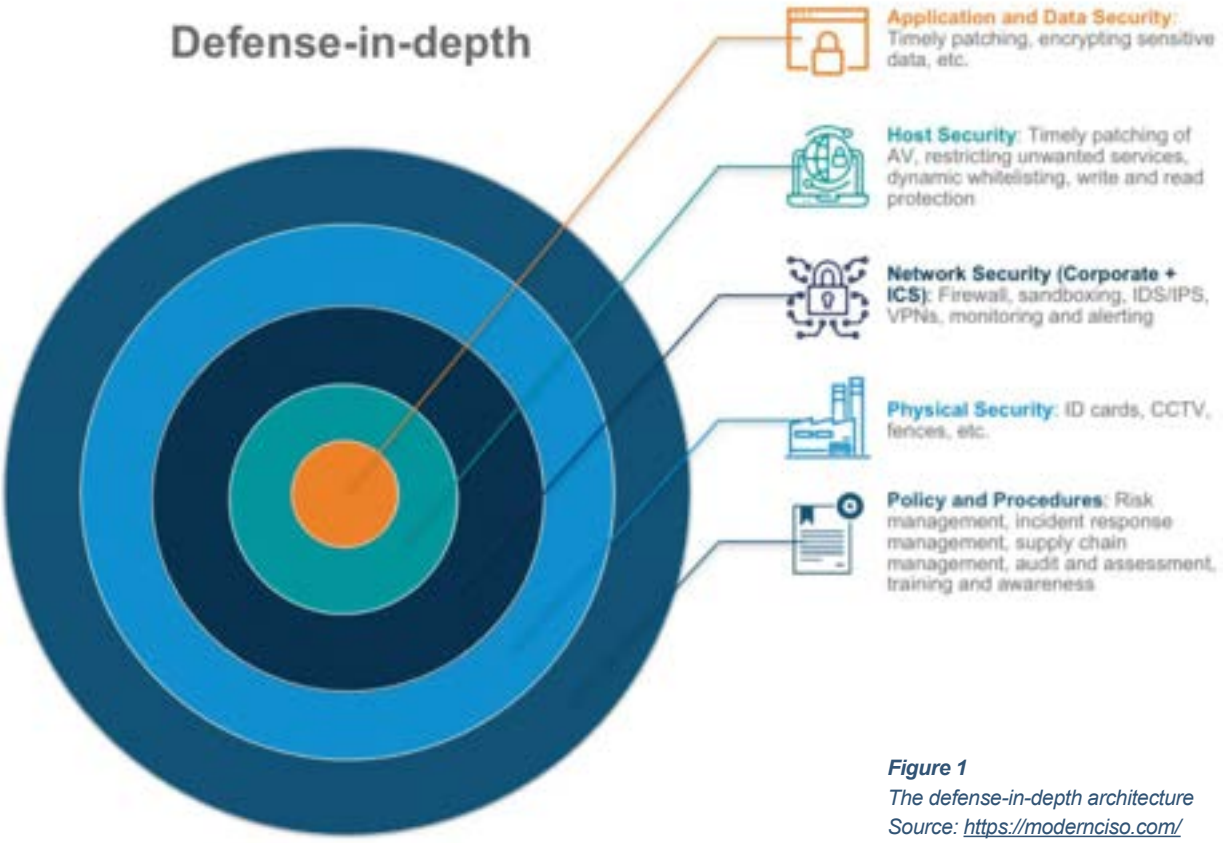


Figure 1
The defense-in-depth architecture
Source: https://modernciso.com/

The defense-in-depth approach is considered an effective strategy that reduces the chance of a successful cyber attack and minimizes the damage that it may cause.

THE "ZERO TRUST" ARCHITECTURE

The continuous improvement and evolution of cybercrime offensive methods, as well as the increasing complexity of modern computer systems described above, have relatively recently led to the emergence of a new security architecture model, known as "zero trust".

Zero trust is a security model, a set of system design principles and a coordinated strategy, which assumes that threats are inherent in both inside and outside traditional network perimeters. In particular, the fundamental principles of the model are:[2]

- *"Never trust, always verify"*: every user, device, application, and data stream are considered untrustworthy. Each of the above must be authenticated and then explicitly authorized with the minimum required privileges.

- *"Assume breach"*: It is considered that the corporate devices and network may have already been compromised by a malicious actor. The "deny-by-default" principle applies to every user, device, application, and data access request. Access is granted after multiple parameters are thoroughly examined (e.g., username, device name and location, time, previously recorded user behavior, etc.).

The zero trust approach incorporates highly detailed monitoring procedures. All access requests, configuration changes and network traffic are maintained in log files, which are constantly automatically monitored for suspicious activity. The model recognizes that any access approval to critical resources carries risks and requires immediate incident preparedness, damage assessment, and operational recovery.

[2] *National Security Agency, (February 2021). Embracing a Zero Trust Security Model. U.S.A. Available from: https://media.defense.gov/2021/Feb/25/2002588479/1/1/0/CSI_EMBRACING_ZT_SECURITY_MODEL_UOO115131-21.PDF.*

Figure 2 shows an example of a zero trust application, where the attacker has compromised the credentials of a legitimate user and is trying to gain access to the organization's systems.

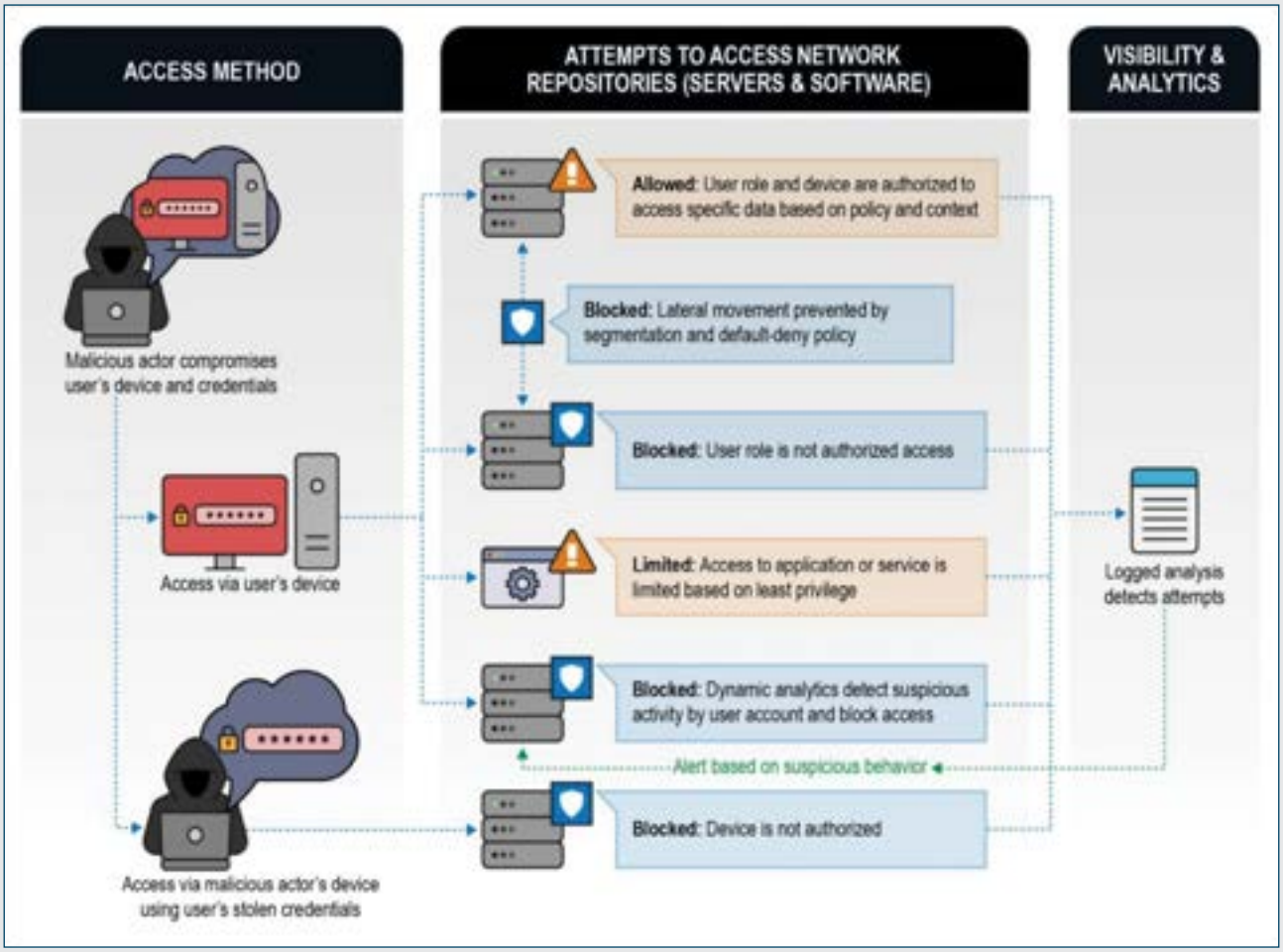


Figure 2
Example of a "zero trust" architecture
Source:https://media.defense.gov/2021/Feb/25/2002588479/1/1/0/CSI_EMBRACING_ZT_SECURITY_MODEL_UOO115131-21.PDF

2. ASSESSING THE RISK

Organizations are increasingly dependent on information and communication technologies to perform their day-to-day operations and overall mission. These technologies are subject to *threats*, which exploit known and unknown system *vulnerabilities* with potentially severe *impact* for operational procedures, individual safety, critical infrastructure, and national security, due to breaches of confidentiality, integrity, and availability of the information that these systems process, store or transmit. Threats to information technology include cyberattacks, human error, environmental disasters, and structural failures.

For the above reason, it is imperative for the top management to become conscious of their responsibility and to *establish a holistic organizational risk management approach* in relation to the operation and use of network and information systems.

A key component of a risk management framework is *risk assessment*, which consists of the following series of actions:[3]

- *Identification of threat sources* related to the organization (malicious groups, competitors, other states, physical threats, errors, etc.).
- *Identification of the actions / threat events* that could occur from the above threat sources (cyber attacks, natural disasters, material damage, etc.).
- *Identification of the organization's vulnerabilities* that a threat source could exploit through specific actions / events.
- *Estimation of the probability* that the identified threat sources will take specific actions and of the probability of successful completion of them.
- *Assessment of the adverse effects* (on the functions and systems, on individuals, on other organizations or on national security itself) in case that the actions / events take place.
- *Determination of the risk to organizational security* by calculating the combination (i) of the probability of occurrence of the events and (ii) of the adverse effects in case the events take place.

Based on the calculated risk, the organization will *select the appropriate protection measures*, such as those described in Part B of the Handbook, for the risks to be adequately addressed.

Also, the organization should develop an *information security policy*, which will define, at a high level, the security objectives, and the organizational approach in achieving them, while it will refer to more specific thematic policies and procedures that will specify the implementation and application of the selected protection measures.

[3] National Institute of Standards and Technology (NIST), (September 2012). Guide for Conducting Risk Assessments (Special Publication 800-30 revision 1). U.S. Department of Commerce. Available from: https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final.

Risk management is always the starting point for an effective approach to cybersecurity. Thus, an organization – as a whole – should establish an *information security management system*, which:

(i) will be implemented through the deployment of risk-based technical and organizational cybersecurity measures,

(ii) will have the full financial and organizational support of the senior management,

(iii) will be regularly assessed and updated and

(iv) will create a common cybersecurity culture among all stakeholders (senior management, employees, providers, and suppliers).[4]

For an information security management system to be effectively implemented, an appropriate department responsible for the security of network and information systems should be established within every organization. This department should:

(i) be equipped with the appropriate roles and responsibilities,

(ii) be adequately staffed with individuals with the necessary technical and legal expertise on cybersecurity issues and

(iii) have at its disposal the necessary resources to achieve the cybersecurity objectives.

APPOINTMENT OF CHIEF INFORMATION SECURITY OFFICER (CISO)

Finally, an organization should designate a person with the appropriate technical and organizational qualifications as Chief Information Security Officer (CISO). A CISO is formally responsible for providing strategic level guidance to the organization so as to deal with cybersecurity issues, supervising and monitoring the implementation of the information security management system, and ensuring that the entity complies with relevant legislation and regulations. As a role, it presupposes the existence of necessary leadership skills and the ability to align cybersecurity objectives with operational objectives within the organization.

[4] Two examples of internationally recognized standards are ISO 27001:2013 (https://www.iso.org/standard/54534.html), as well as NIST Cybersecurity Framework (https://www.nist.gov/cyberframework).